MONEY MITRA NETWORK

TASK 4: CYBER SECURITY ASSESSMENT AND INCIDENT RESPONSE

Final Assessment Report

Submitted By: Sudip Kumar Chaurasiya

College: Model Institute of Technology (MIT)

Programme: Bachelor of Information Technology (BIT)

Submitted To: Money Mitra Network

Date: 24 October 2026

GitHub Evidence Repository

https://github.com/sudipchaurasiya/Money-Mitra-Network-Task-4-Cybersecurity-Assessment

Scope note: The vulnerable lab assessment and the supplied PCAP investigation are separate evidence sets. Their findings are not assumed to describe the same incident.

1. Executive Summary

This assessment combines an authorized scan of a deliberately vulnerable Metasploitable 2 lab with a separate review of a supplied network packet capture. The lab scan identified multiple exposed legacy services. The strongest confirmed lab findings are an exposed root bind shell on TCP/1524 and anonymous FTP login on TCP/21. The HTTP service also reported old Apache and PHP versions. These observations justify remediation in the lab but do not demonstrate that a production system was compromised.

In the PCAP, the internal client 10.10.1.128 requested an executable from 107.175.82.242:9000. A matching HTTP 200 response was observed. The recovered file was identified as a PE32+ Windows executable and its SHA-256 was recorded. The file was not executed. A separate long encrypted connection to 195.63.128.106:443 and HTTP redirects for holtandberyl.com are investigation leads; their purpose and maliciousness remain unverified.

Overall assessment: confirmed exposure in the intentionally vulnerable lab; confirmed network observations in the supplied capture; no confirmed malware execution, successful compromise, or data exfiltration.

2. Scope, Authorization and Environment

Lab target: 192.168.1.3 (Metasploitable 2). Kali assessment host: 192.168.1.5. The lab was accessed through the user's VirtualBox lab network. PCAP investigation used the supplied file 2026-10-01-traffic-analysis-exercise.pcap and the recorded internal client 10.10.1.128. These are separate scopes.

Included: Nmap service/version discovery, targeted banner and anonymous FTP checks, HTTP header review, packet-capture analysis, file identification and hashing, evidence organization, detection logic, risk prioritization, and an incident-response plan.

Excluded: public scanning, contacting remote infrastructure, executing the recovered executable, claiming a production incident, or asserting vulnerabilities that were not tested. The assessment reflects the evidence available at the time of writing.

3. Methodology and Tools

Tools used: Nmap, TShark/Wireshark, file, sha256sum, text/CSV evidence records, Python, ReportLab and openpyxl. The lab scan used service/version and OS detection. A targeted scan checked selected services and scripts for banners, HTTP information and anonymous FTP. PCAP analysis used packet numbers, timestamps, protocol fields, HTTP requests/responses, DNS responses and TCP conversation summaries.

Reproducibility: full saved scan outputs and supporting evidence remain in the task4-evidence folder. The PCAP SHA-256 recorded during verification is:

287d6dee90cfef71f98a97c42e30444608de2cf59d2f7392a0a6df8dbbc8274b

A TShark plugin warning was observed during analysis, but the documented commands returned data. This is a tooling limitation worth recording; it does not by itself invalidate the extracted observations.

4. Lab Assessment Findings

The Nmap output reports 23 open TCP services on 192.168.1.3. Selected confirmed services and banners are summarized below. A service banner proves that a service responded; it does not automatically prove exploitability.

Port/service	Observed evidence	Assessment
21/tcp FTP	vsftpd 2.3.4; anonymous FTP login returned code 230. Directory listing was empty.	Anonymous access confirmed; no exposed files demonstrated.
23/tcp Telnet	Linux telnetd detected.	Cleartext remote administration service exposure; access controls not tested.
80/tcp HTTP	Apache 2.2.8 (Ubuntu) DAV/2; PHP 5.2.4 in HTTP headers.	Legacy software versions observed; specific exploitability not tested.
1524/tcp bind shell	Banner returned root@metasploitable:/#.	Critical-priority exposure in this intentionally vulnerable lab; remove/restrict and rebuild.
3306/tcp MySQL	MySQL 5.0.51a-3ubuntu5.	Legacy database service exposed; authentication and data access not tested.
5432/tcp PostgreSQL	PostgreSQL 8.3.0–8.3.7.	Legacy database service exposed; authentication and data access not tested.
Other services	SSH, SMTP, DNS, RPC, Samba, rexec/login/rsh, Java RMI, NFS, VNC, X11, IRC, AJP and Tomcat also detected.	Review business need and access restrictions; individual vulnerabilities not confirmed.

Prioritized Lab Risks

V-01 Critical priority: exposed root bind shell on TCP/1524. Evidence: service identification and root-shell banner. Rationale: the exposed service presents a direct root-level access risk in the lab. Remediation: disable/remove the service, isolate the host, rebuild from a trusted image, and verify the port is closed.

V-02 High priority: anonymous FTP login on TCP/21. Evidence: FTP code 230. The listing was empty, so no file disclosure is claimed. Remediation: disable anonymous access unless explicitly required, restrict source networks, and use secure file transfer.

V-03 High priority: legacy Apache/PHP stack on TCP/80. Evidence: Apache 2.2.8 and PHP 5.2.4 banners. Remediation: migrate to supported versions, remove unnecessary modules and retest. The version evidence alone does not confirm a specific CVE.

V-04 High priority: Telnet on TCP/23. Disable it or restrict administrative access to a secure management path.

V-05 High priority: legacy database services on TCP/3306 and TCP/5432. Restrict network reachability and verify authentication/configuration. No successful database login is claimed.

V-06 Medium priority: additional legacy services. Confirm business need, apply supported updates, and restrict exposure. Severity is qualitative and no CVSS score is asserted.

5. PCAP Investigation and Timeline

The packet capture is separate from the lab scan. Its SHA-256 is recorded above. The following events are grounded in packet numbers and extracted fields.

Time / relative time	Packet evidence	Observation	Interpretation
92.641104 s	8228; DNS	Client queried holtandberyl.com.	Domain lookup observed; intent unknown.
92.815468 s	8230–8231	DNS response associated the domain with 35.170.55.9.	Resolution observed.
~92.95 s	8235, 8238	HTTP request for /prw followed by HTTP 301 to HTTPS.	Redirect confirmed; not inherently malicious.

Time / relative time	Packet evidence	Observation	Interpretation
~94.38 s	8345, 8347	HTTP request for /crv followed by HTTP 301 to HTTPS.	Redirect confirmed; purpose unverified.
15:30:36.806810 -0400	23091	GET /wilow/runner_ilove.exe to 107.175.82.242:9000.	Executable request confirmed.
15:30:38.580040 -0400	24916	HTTP 200 response for the executable path; Content-Length 1,646,592.	Response observed; not proof of execution or maliciousness.
15:30:44.328983 -0400 onward	24963; TCP stream 130	Connection to 195.63.128.106:443; summary reports 15,595 packets, about 14 MB and about 2,233.64 seconds.	Encrypted long-lived connection; purpose unresolved.

6. File Verification and Indicators

The file runner_ilove.exe was identified as a PE32+ Windows GUI executable for x86-64 with eight sections and size 1,646,592 bytes. Its SHA-256 is b789adce70c028a6d17be45ec34667aa95586350ee0c4057e75b138b1ad35061. The file was not executed. The hash identifies the recovered file; it does not by itself prove maliciousness.

Type	Indicator	First Observed	Packet Evidence	Status	Notes
IP and Port	107.175.82.242:9000	189.451928 seconds	23091 and 24916	Confirmed observation	HTTP GET requested runner_ilove.exe and HTTP 200 response observed; maliciousness not confirmed
File	runner_ilove.exe	2026-10-01 15:30:36 -0400	23091 and 24916	Confirmed observation	PE32+ Windows executable; file was not executed
SHA256	b789adce70c028a6d17be45ec34667aa95586350ee0c4057e75b138b1ad35061	File verification	Recovered file hash	Confirmed file hash	Hash identifies the recovered file but does not prove maliciousness
Domain	holtandberyl.com	92.641104 seconds	8228 8235 8238 8345 8347	Unverified lead	Requests to /prw and /crv returned HTTP redirects to HTTPS
IP	35.170.55.9	92.815468 seconds	8230 8235 8238 8345 8347	Unverified lead	DNS resolution and HTTP traffic observed; purpose not established
IP and Port	195.63.128.106:443	196.974101 seconds	Stream 130 and related packets	Unresolved lead	Long encrypted connection; application purpose and maliciousness unverified

Type	Indicator	First Observed	Packet Evidence	Status	Notes
Domain	wpad.natureforce.com	Early in capture	Packet 32 and repeated DNS responses	Inconclusive	Repeated NXDOMAIN responses may be caused by normal proxy discovery

IOC interpretation

Confirmed observations: the executable request/response, recovered file type and hash. Unverified leads: holtandberyl.com and 35.170.55.9, whose HTTP purpose is not established. Unresolved lead: 195.63.128.106:443. Inconclusive DNS observations include repeated NXDOMAIN responses for wpad.natureforce.com, which can occur with normal proxy auto-discovery. Do not block or label an indicator malicious solely because it appears in this capture.

7. Detection Engineering

Wireshark display filters

1. ip.addr == 107.175.82.242 && tcp.port == 9000 — review traffic to the observed executable-download endpoint.

2. http.host == "holtandberyl.com" && (http.request.uri == "/prw" || http.request.uri == "/crv") — inspect the observed HTTP paths.

3. dns.flags.response == 1 && dns.flags.rcode != 0 — review DNS error responses; expected false positives include failed lookups and WPAD discovery.

Two documented Sigma-compatible pseudocode rules are included in the workbook and source evidence. They are illustrative detection logic, not certified deployable Sigma YAML. A production SOC should adapt them to the actual log schema, add thresholds and test false-positive rates before enabling blocking.

SOC usage: alert on the network observation, enrich with endpoint process and proxy/DNS logs, validate asset owner and business purpose, preserve packet references, and escalate only when corroborating evidence supports it.

8. Benign Explanations and Follow-up

Benign possibility 1: holtandberyl.com requests and HTTP 301 responses may reflect normal HTTP-to-HTTPS redirection. To evaluate this, establish whether the domain and paths were expected for the endpoint and review browser/proxy history and approved business use.

Benign possibility 2: the long encrypted connection to 195.63.128.106:443 may be a legitimate application, cloud service or software update. Review endpoint process telemetry, destination ownership/reputation from trusted sources, available TLS metadata and asset-owner confirmation. The capture alone does not establish its purpose.

The repeated WPAD DNS failures may also be ordinary proxy auto-discovery behavior. Confirm the endpoint's proxy configuration and resolver policy before treating these as a security incident.

9. Incident Response Plan

Preparation: maintain asset inventory, approved scope, logging, time synchronization, backups and tested response contacts. Identification: preserve the original PCAP and its hash; record packet numbers and timestamps; validate indicators against endpoint and DNS/proxy logs. Containment: if corroborating evidence supports compromise, isolate the affected endpoint using approved procedures and restrict confirmed malicious destinations through change control. Do not claim these actions were performed unless separately documented.

Eradication: remove confirmed persistence or malicious artifacts only after collection and validation; rebuild or patch affected systems as appropriate. Recovery: restore from trusted sources, validate service state, monitor for recurrence and obtain owner approval. Lessons learned: tune detections, review exposure, document decisions and retain evidence according to policy.

Prioritized recommendations

1. Disable/remove the lab root bind shell and verify TCP/1524 is closed. 2. Disable anonymous FTP or tightly restrict it. 3. Upgrade unsupported Apache/PHP and database services to supported versions. 4. Disable Telnet and unnecessary legacy remote services; use secure administration. 5. Restrict database and management ports by network segmentation and least privilege. 6. Add monitoring for executable downloads on unusual ports, DNS failures and long-lived outbound encrypted connections. 7. Correlate network alerts with endpoint process, proxy and DNS logs before declaring compromise. 8. Keep the recovered executable unexecuted and handled as an untrusted file.

10. Limitations and Unresolved Questions

No claim is made that the executable ran, the PCAP client was compromised, data was exfiltrated, or the long encrypted connection was command-and-control. The purpose of 195.63.128.106:443 remains unresolved. The HTTP redirects may be benign. DNS errors are inconclusive. The lab is intentionally vulnerable and separate from the PCAP environment. Some service configurations, authentication controls and individual vulnerabilities were not tested. No CVSS values are supplied because a complete, reliable scoring basis was not established.

A TShark plugin warning occurred during extraction; commands still returned the recorded results. Repeat critical queries with a healthy tool installation if a higher-assurance forensic review is required.

11. Evidence Screenshots

Screenshots are included as supporting visual evidence. Text outputs and packet numbers remain the primary reproducible records.

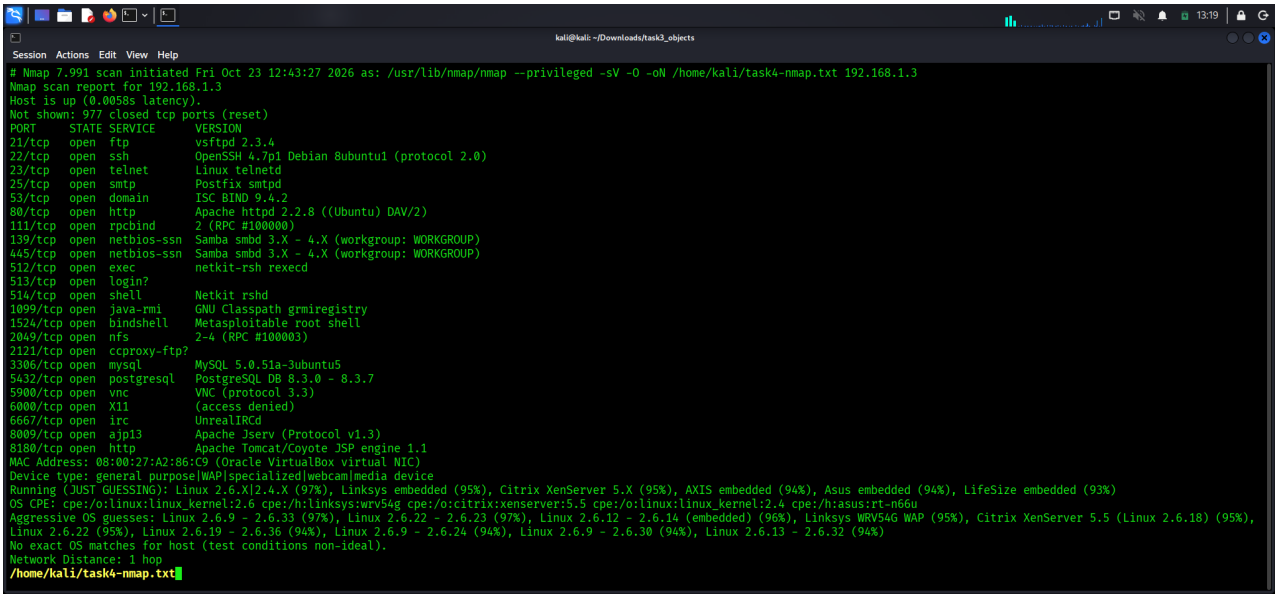


Figure 1. Nmap open-port evidence.

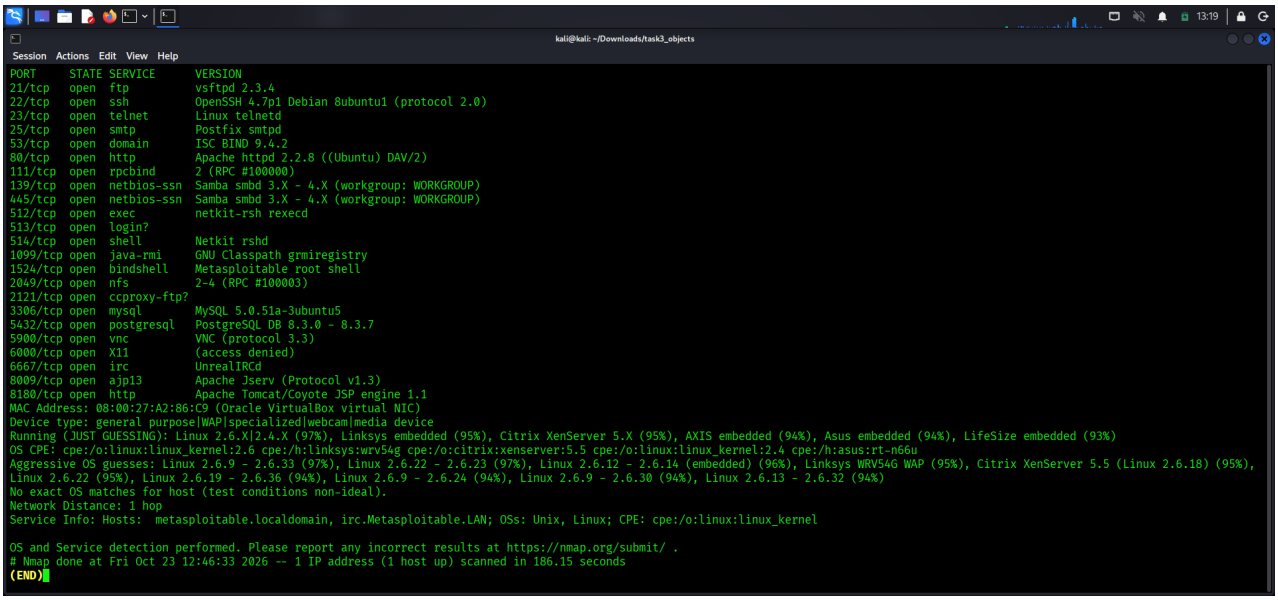


Figure 2. Remaining Nmap service results.

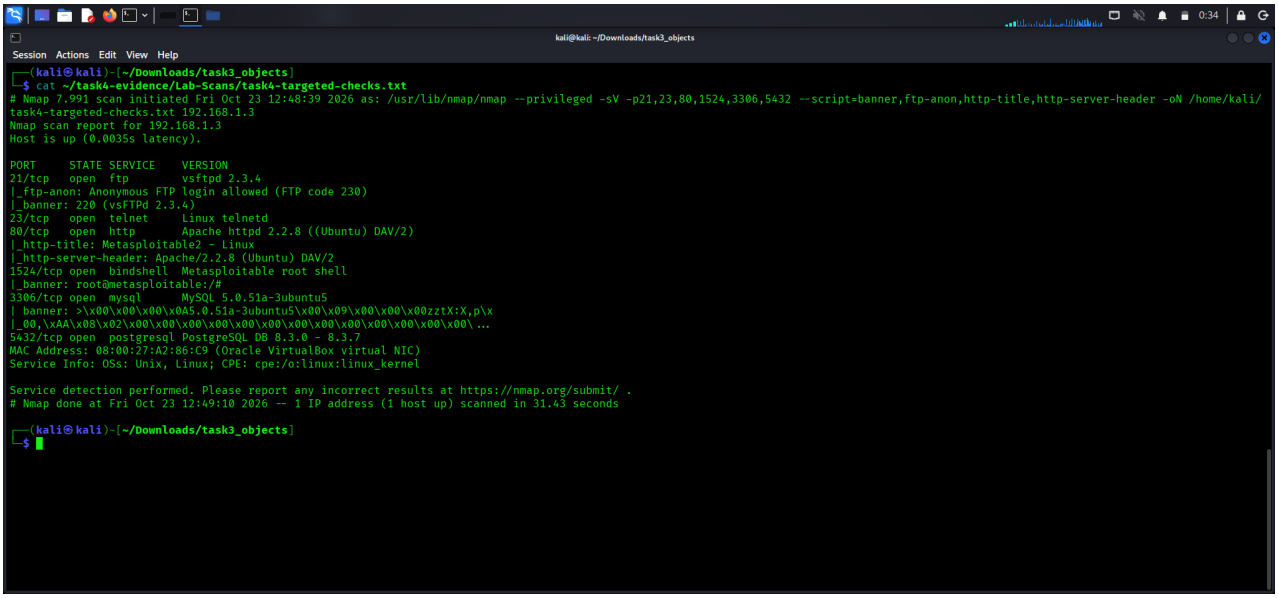


Figure 3. Targeted service/banner checks.

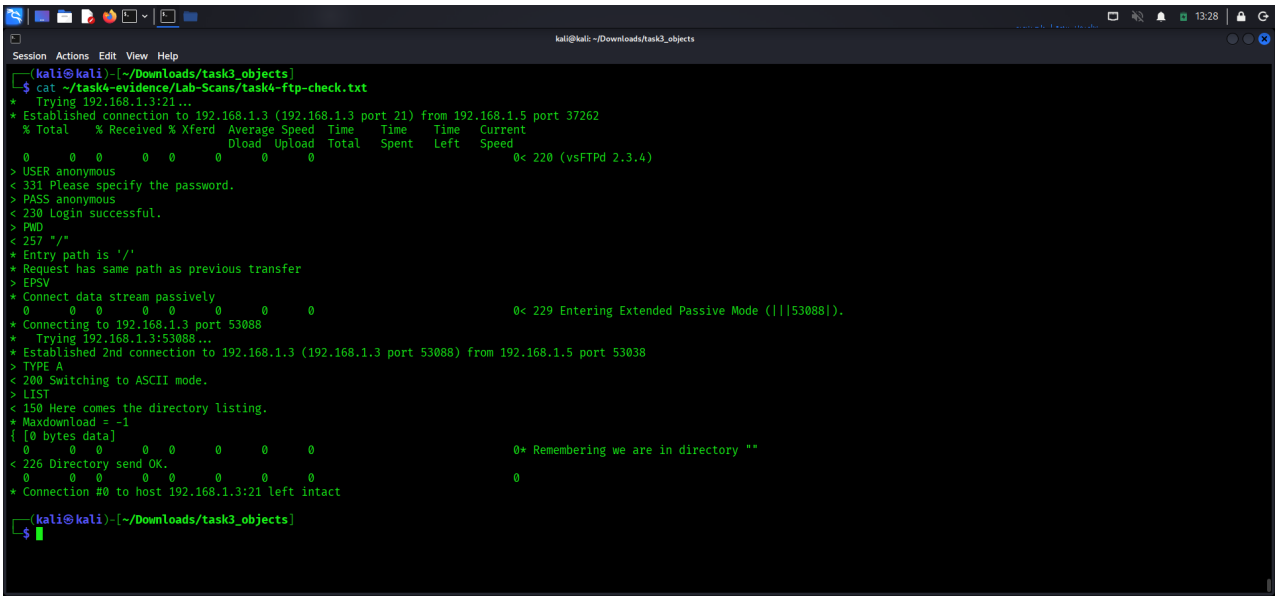


Figure 4. Anonymous FTP login evidence.

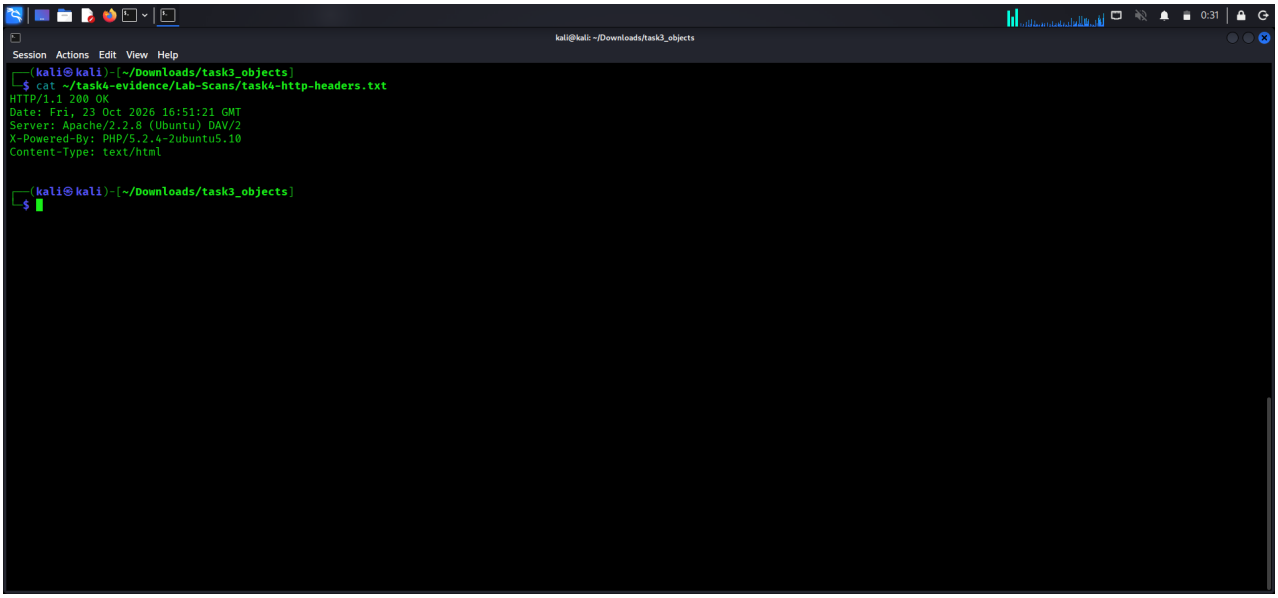


Figure 5. HTTP server header evidence.

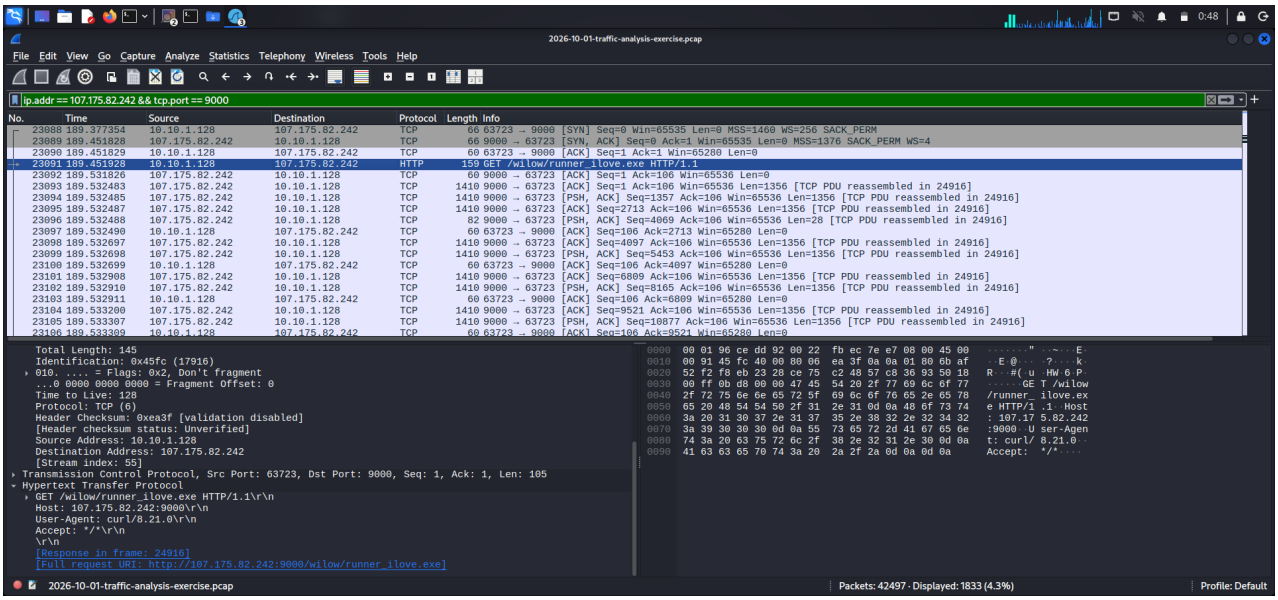


Figure 6. PCAP executable request/response evidence.

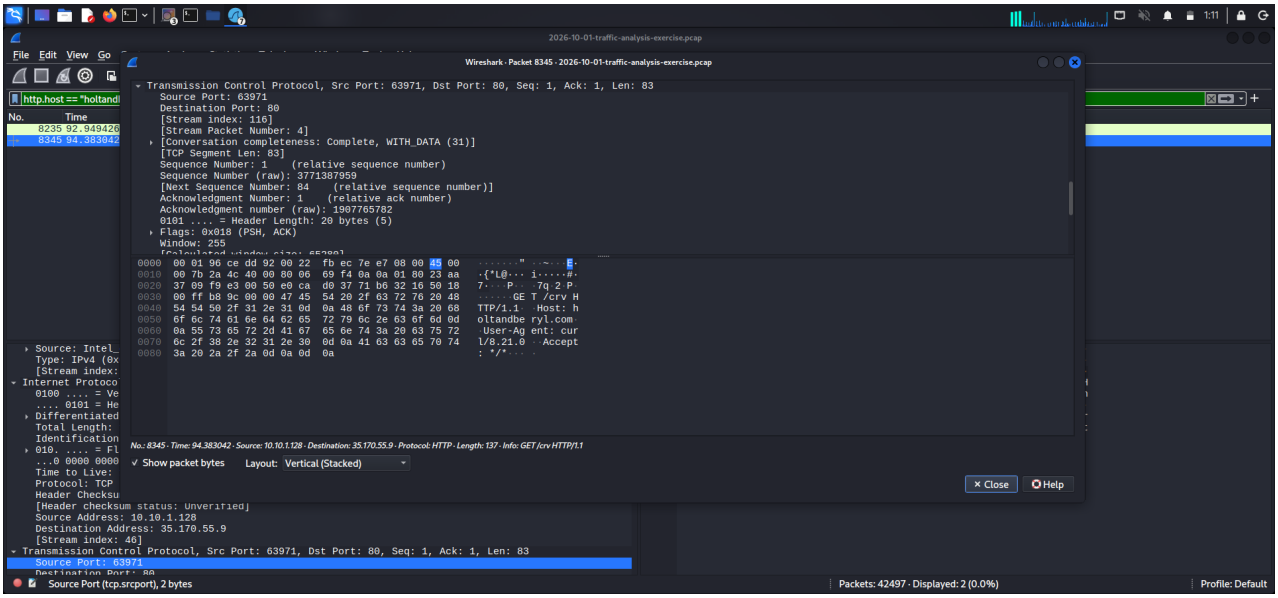


Figure 7. PCAP HTTP redirect evidence.

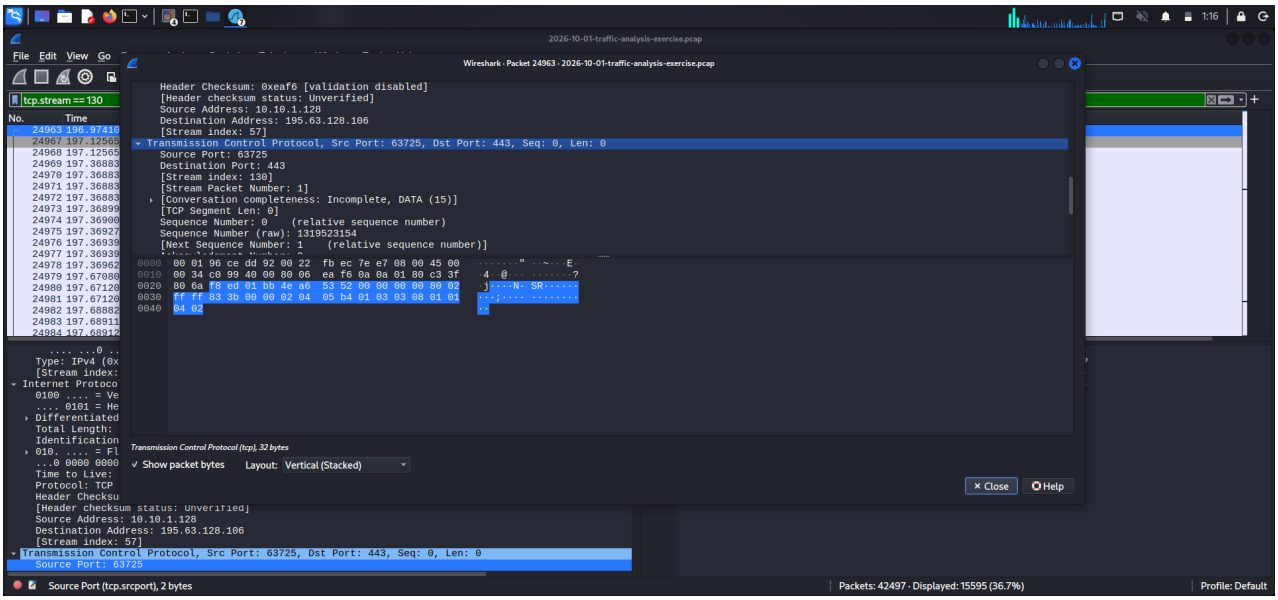


Figure 8. Long-lived encrypted connection evidence.

12. References

National Institute of Standards and Technology. (2012). Computer security incident handling guide (Special Publication 800-61 Revision 2). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-61r2

National Institute of Standards and Technology. (2008). Technical guide to information security testing and assessment (Special Publication 800-115). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-115

Wireshark Foundation. (n.d.). Wireshark User's Guide. https://www.wireshark.org/docs/wsug_html_chunked/

Note. Technical findings are based on the lab outputs, supplied packet capture, extracted evidence records and screenshots listed in the appendices and evidence workbook.

Appendix A. Reproducible Lab Commands

Full scan: nmap --privileged -sV -O -oN /home/kali/task4-nmap.txt 192.168.1.3

Targeted checks: nmap --privileged -sV -p21,23,80,1524,3306,5432
--script=banner,ftp-anon,http-title,http-server-header -oN /home/kali/task4-targeted-checks.txt 192.168.1.3

PCAP executable request/response evidence is recorded in executable-http-details.tsv. Redirect evidence is recorded in redirect-details.tsv. The timeline, IOC table, risk register, detection notes and response plan are preserved in the evidence directory and summarized in the workbook.

Appendix B. Source Evidence

PCAP SHA-256: 287d6dee90cfef71f98a97c42e30444608de2cf59d2f7392a0a6df8dbbc8274b

Source folder: ~/task4-evidence. Final submission folder: ~/task4-final-output. The source evidence folder is retained separately and is not renamed by this script.